

NETWORKWALKS

CONFIDENTIAL TRAINING ENGAGEMENT

Black-Box Penetration Test Report

Mediroza General Hospital

Target	https://medirozahospital.com
Client	Mediroza General Hospital
Engagement Type	Full Black-Box Penetration Test
Program / Batch	Networkwalks Penetration Testing Training Program — Batch B082, Week 4
Prepared By	Mishal
Duration	3 Days
Report Status	Final — All Milestones (M1–M4) Completed
Classification	Confidential — Authorised Personnel Only

Authorisation Statement

This assessment was conducted in a controlled training environment against a system for which explicit written authorisation was granted by the client. No technique documented in this report was, or should be, applied to any system without equivalent written permission from the owner.

Liability Disclaimer

This report reflects the state of the target system at the time of testing only and does not constitute a guarantee that the system is free of other vulnerabilities. Networkwalks and the author of this report accept no liability for any actions taken, or not taken, by the client as a result of this report, nor for any damage arising from misuse of the information it contains. All findings, credentials, and recovered data documented herein were obtained solely for the purposes of this authorised training engagement and must not be used, shared, or replicated outside the scope of this exercise.

1. Executive Summary

Networkwalks conducted a three-day, full black-box penetration test against Mediroza General Hospital's public-facing web application at <https://medirozahospital.com>. The objective was to identify exploitable vulnerabilities, demonstrate their real-world business impact, and provide the client with clear, actionable remediation guidance.

The assessment identified a critical chain of vulnerabilities beginning with a SQL injection flaw in the patient portal's login form. This flaw allowed the login process to be bypassed entirely without any valid credentials. Once authenticated, the portal failed to apply proper authorisation checks and returned confidential lab reports belonging to multiple unrelated patients rather than restricting access to a single verified identity. Those documents were further protected only by weak, easily guessed passwords, which were recovered using standard offline techniques.

Independently of the patient portal, a legacy directory on the webserver (/old/) was found to have directory listing enabled and was reachable without any authentication. This exposed a full database backup file containing internal human resources records — including staff salaries, national identification numbers, and contact details — as well as a complete shareholder and ownership register for the hospital. This is assessed as the most severe finding of the engagement, given the sensitivity and completeness of the data exposed.

Taken together, these findings represent a critical risk to Mediroza General Hospital. An external attacker with no prior access or credentials could, within a short period of time, obtain protected health information for multiple patients, personally identifiable information and compensation data for the entire workforce, and confidential ownership records for the organisation.

Overall Risk Rating

Critical

Findings Summary

ID	Finding	Category	Risk
F1	SQL injection leading to authentication bypass on the patient portal login	Broken Authentication	Critical
F2	Broken access control — authenticated session exposes lab reports belonging to all patients, not just one identity	Broken Access Control	High
F3	Weak, guessable passwords protecting distributed patient PDF documents	Weak Cryptographic Protection	High
F4	Unauthenticated directory listing on a legacy path (/old/)	Security Misconfiguration	Critical

F5	Exposed database backup file containing internal HR records	Sensitive Data Exposure	Critical
F6	Exposed shareholder / ownership register within the same backup	Sensitive Data Exposure	Critical

2. Scope and Rules of Engagement

Target	https://medirozahospital.com
Engagement Type	Full black-box penetration test — no credentials, source code, or internal documentation were provided at the outset
Rules of Engagement	Testing limited strictly to the target domain. No social engineering. No denial-of-service testing. No testing outside the agreed scope.
Authorisation	Written authorisation was provided by the client prior to the commencement of testing
Duration	3 days

3. Project Milestones

This engagement was structured around four defined milestones, each with written client authorisation. All four were completed during the assessment.

ID	Milestone	Objective	Status
M1	Initial Access	Attack the website and retrieve 3 confidential patient PDF lab reports.	Complete
M2	Data Extraction	Crack the encryption/passwords on all 3 retrieved files.	Complete
M3	Critical Exposure	Identify a further critical data exposure on the client server, uncovering staff salaries and shareholder details.	Complete
M4	Reporting	Produce this professional penetration testing report for the client.	Complete

4. Methodology

The assessment followed a standard black-box methodology comprising reconnaissance, manual analysis of application logic, exploitation, and post-exploitation analysis of recovered data.

Tools Used

- whois, nslookup, theHarvester — passive and semi-passive reconnaissance
- Gobuster — directory and file enumeration against the web root and legacy paths
- Burp Suite (Repeater / Intruder) — manual request tampering, authentication testing, and input-handling analysis
- Manual SQL injection testing — authentication logic and input validation review
- qpdf — PDF encryption inspection and offline password recovery
- PowerShell scripting — automated wordlist-based password testing against recovered documents
- Custom and public wordlists — including context-derived candidate passwords built from data recovered during the engagement

Limitations

As a black-box engagement, no credentials or internal documentation were supplied. A web application firewall (WAF) was observed blocking certain SQL injection signatures during testing (returning HTTP 403 responses), requiring payload obfuscation to achieve a working bypass. This is noted as a partially effective — but ultimately bypassable — compensating control.

5. Findings and Proof of Exploitation

Findings F1 and F2 correspond to Milestone M1 (Initial Access). Finding F3 corresponds to Milestone M2 (Data Extraction). Findings F4, F5 and F6 correspond to Milestone M3 (Critical Exposure).

F1 — SQL Injection — Authentication Bypass on Patient Portal Login [Milestone M1]

Risk Rating: **Critical** | **Category:** Broken Authentication (OWASP A07:2021)

Description

The patient portal login form at /patient/login.php did not properly validate or parameterise user-supplied input before using it in a backend SQL query. This allowed the authentication check to be bypassed entirely without knowledge of any valid password.

Technical Detail

- Baseline testing established that the application discloses whether a submitted username exists (a distinct 'username not found' message versus 'incorrect password'), enabling username enumeration and confirming that 'admin' is a valid account.
- A raw SQL syntax error was successfully triggered by submitting a single-quote-based payload in the password field, returned directly in the HTTP response body — definitive confirmation that user input was being concatenated directly into a SQL query without sanitisation.

- A comment-based injection payload submitted in the username field (structured to terminate the intended query and comment out the remainder, including the password check) returned an HTTP 302 redirect to portal.php together with a valid authenticated session cookie — a successful authentication bypass with no valid credentials supplied.
- A web application firewall blocked unobfuscated payloads (e.g. simple ' OR '1'='1 patterns) with HTTP 403 responses; lightly obfuscated equivalents were not blocked, indicating the WAF's signature coverage was incomplete.

Evidence

- Screen captures of the Burp Suite Repeater request and HTTP 302 response showing the issued session cookie and Location: portal.php header (submitted payload redacted per engagement handling rules).
- Screen capture of the raw MySQL syntax error returned in the login page HTML.

Business Impact

This is the root-cause vulnerability of the entire attack chain. It allows any unauthenticated external party to gain a fully authenticated session on the patient portal without any valid credentials, directly enabling the data exposure documented in F2.

Recommendation

- Use parameterised queries / prepared statements for all database interactions; never concatenate user input into SQL statements.
- Apply least-privilege database account permissions to the application's database user.
- Do not disclose whether a username exists via differing error messages; return a single generic authentication failure message.
- Extend WAF signature coverage to catch obfuscated and case-varied injection patterns, and treat the WAF as a compensating control only, not a substitute for input validation.

F2 — Broken Access Control — Cross-Patient Data Exposure [Milestone M1]

Risk Rating: High | **Category:** Broken Access Control (OWASP A01:2021)

Description

Once authenticated (via F1), the patient portal's 'My Reports' page returned lab report records belonging to multiple, unrelated patients rather than scoping results to a single verified patient identity.

Technical Detail

- The authenticated portal.php page listed pathology reports for at least three distinct, unrelated patients, each with its own lab reference number and a direct download link (download.php?id=N).
- No server-side check was observed tying the returned records to the specific authenticated identity, indicating an absence of object-level authorisation on this endpoint.

Evidence

- Screen capture of the portal.php response listing multiple patient report rows with distinct names and lab reference numbers redacted for this report.

Business Impact

Any session that clears authentication — including the one obtained via F1, but potentially also any legitimately issued patient session — can view and download confidential medical records belonging to other patients. This compounds the severity of F1 significantly and constitutes unauthorised disclosure of protected health information.

Recommendation

- Enforce server-side authorisation on every record request, scoped strictly to the authenticated user's own identity.
- Adopt indirect object references (opaque, per-user tokens) rather than sequential, guessable record identifiers.
- Log and alert on access patterns where a single session retrieves records associated with multiple distinct patient identities.

F3 — Weak Protection on Distributed Patient Documents [Milestone M2]

Risk Rating: High | **Category:** Cryptographic Failures (OWASP A02:2021)

Description

The three PDF lab reports retrieved via F1/F2 were each protected with a user password (required to open the file). However, the passwords chosen were weak, low-entropy, and trivially guessable, and all three were recovered offline within minutes using common password lists.

Technical Detail

- qpdf was used to confirm each PDF required a user password (rather than only an owner/permissions password) before it could be opened.
- An automated PowerShell routine iterated candidate passwords against each file using qpdf --decrypt, testing common-password wordlists sequentially, confirming the milestone guidance that a single wordlist or approach would not necessarily work for all three files.
- Report 1 (patient: S. Dlamini) — password recovered: 123456
- Report 2 (patient: P. Reddy) — password recovered: password
- Report 3 (patient: E. Thompson) — password recovered: !@#\$%^&

Evidence

- Terminal output showing successful qpdf decryption and the recovered password for each of the three files.
- Screen capture of a successfully decrypted report (E. Thompson, Patient ID MG-P-10258, DOB 1978-09-03) displaying patient test results.

Business Impact

Passwords of this strength — including two of the most common passwords in the world, and a short keyboard-pattern string — provide negligible protection against an attacker who has already obtained the encrypted file; offline recovery took only minutes with publicly available wordlists. Given the sensitivity of the contents (protected medical test results for named patients), this represents a meaningful failure of the confidentiality control the hospital relies on to protect these documents in transit or at rest.

Recommendation

- Apply strong, unique, randomly generated passwords or key-based encryption to any document containing personal or medical information; never reuse a small, guessable password set across documents.
- Deliver document passwords to patients via a separate, authenticated channel rather than a predictable or shared default.
- Consider replacing password-protected PDF distribution with an authenticated, per-session download mechanism that does not rely on document-level passwords at all.

F4 — Unauthenticated Directory Listing on Legacy Path (/old/) [Milestone M3]

Risk Rating: **Critical** | Category: Security Misconfiguration (OWASP A05:2021)

Description

Directory enumeration identified a legacy directory (/old/) on the production webserver. This directory mirrored the site's public pages but also contained a leftover file that was never intended for public distribution, and was reachable by any unauthenticated visitor.

Technical Detail

- Gobuster directory enumeration against the web root identified /old/ (HTTP 301) among a small number of top-level directories.
- Within /old/, a database backup file (named in a predictable, dated pattern) was retrieved directly via HTTP with no authentication required.

Evidence

- Gobuster output listing the discovered /old/ path.
- Raw HTTP response confirming unauthenticated download of the backup file (exact filename withheld from this public-facing report).

Business Impact

This finding provided a completely independent path to critical data exposure (F5, F6) requiring no authentication, no exploitation of application logic, and no interaction with the vulnerable login form at all — it is exploitable by any anonymous internet user who happens to guess or brute-force the path.

Recommendation

- Disable directory listing at the webserver configuration level.

- Remove all legacy/backup directories and files from the public web root; store backups outside of any web-accessible path.
- Implement a routine process for identifying and removing stale, forgotten artefacts left behind by deployments, migrations, or CMS backup modules.

F5 & F6 — Exposed HR Records and Shareholder / Ownership Register [Milestone M3]

Risk Rating: Critical | Category: Sensitive Data Exposure (OWASP A01:2021 / A02:2021)

Description

The database backup retrieved in F4 contained two complete tables: a staff records table and a shareholder register, both of which were fully readable in plaintext within the SQL dump.

Technical Detail

- The staff table contained full names, job titles, departments, work email addresses, phone numbers, national identification numbers, monthly salaries, and dates of joining for the entire workforce (30 employee records).
- The shareholders table contained shareholder names, ownership percentages, number of shares held, and share class for all recorded equity holders.
- No encryption, access control, or masking was applied to either table within the backup file.

Evidence

- Copy of the recovered SQL backup content (raw data withheld from this public-facing report; full unredacted data was provided separately and securely to the client and training instructor).

Business Impact

This is the most severe finding of the engagement. Exposure of national identification numbers combined with full names, contact details, and compensation data creates a significant identity-theft and targeted social-engineering risk for every affected employee, and may trigger data-breach notification obligations under applicable privacy law. Exposure of the shareholder register additionally represents a serious confidentiality breach of the hospital's ownership structure.

Recommendation

- Treat this as a reportable data exposure incident: assess breach notification obligations to affected staff and shareholders under applicable data protection law without delay.
- Immediately remove the exposed backup and audit web server logs for any prior unauthorised access to /old/.
- Store all backups outside the web root, encrypted at rest, with access restricted to authorised administrative personnel only.
- Apply field-level protection (encryption or tokenisation) to highly sensitive fields such as national identification numbers, independent of where the data is stored.

6. Risk Rating Matrix

Risk ratings below reflect the combination of exploitation likelihood (accounting for the skill and access required) and business impact (accounting for data sensitivity and scale of exposure), consistent with a standard qualitative risk methodology.

Finding	Likelihood	Impact	Overall Risk
F1 — Authentication bypass (SQLi)	High	Critical	Critical
F2 — Broken access control	High	High	High
F3 — Weak document passwords	High	High	High
F4 — Directory listing exposure	High	Critical	Critical
F5 — HR data exposure	Medium	Critical	Critical
F6 — Shareholder data exposure	Medium	Critical	Critical

7. Attack Chain (High-Level)

The following sequence illustrates how the individual findings combine into a complete, end-to-end compromise path:

- Patient portal login form targeted with SQL injection (F1)
- Authentication check bypassed — attacker gains a valid, authenticated session with no credentials
- Absence of server-side authorisation (F2) exposes lab reports for multiple unrelated patients
- Weak document passwords (F3) defeated offline, recovering the full contents of the protected reports
- Independently, unauthenticated directory listing (F4) exposes a legacy database backup
- Backup contents disclose complete staff HR records (F5) and the shareholder register (F6)

Notably, findings F4–F6 do not depend on F1–F3 at all: they represent a second, fully independent path to critical data exposure that any anonymous visitor could exploit without ever touching the login form.

8. Recommendations Summary

The following remediation actions are prioritised by urgency and should be read alongside the specific recommendations under each finding in Section 4:

- Immediate: Take /old/ offline or restrict access; rotate/replace the exposed database backup; begin breach-notification assessment for affected staff and shareholders.
- Immediate: Patch the SQL injection in the patient login form using parameterised queries.
- Short-term: Implement server-side, per-identity authorisation checks on all patient record and document endpoints.

- Short-term: Replace weak document passwords with strong, randomly generated, per-document credentials delivered via a separate authenticated channel.
- Ongoing: Establish a routine process to find and remove legacy/backup artefacts from the public web root, and extend WAF rule coverage to close the obfuscation gap identified in F1.

9. Conclusion

This engagement identified a critical, exploitable chain of vulnerabilities affecting Mediroza General Hospital's patient portal, alongside a fully independent and equally critical exposure of internal HR and ownership data via a misconfigured legacy directory. Both paths are exploitable by an unauthenticated external attacker with commonly available tools and require prompt remediation. Addressing the SQL injection root cause, enforcing proper access control, and removing exposed backup data from the public web root should be treated as immediate priorities.

— End of Report —

Prepared by Mishal

Networkwalks Penetration Testing Training Program — Batch B082, Week 4